

Cyber Threat Intelligence

Executive Briefing

Report Date: July 02, 2026

Generated: 2026-07-02 10:14 UTC | Classification: TLP:AMBER

Prepared by: Auto-CTI Autonomous Threat Intelligence Pipeline

1. Risk Statistics Summary

Critical	High	Medium	Low	Total
7	9	4	0	20

2. Executive Summary

As of July 02, 2026, the security operations center has concluded the analysis of 20 identified vulnerabilities, consisting of 7 Critical, 9 High, and 4 Medium severity findings. This distribution indicates an elevated organizational risk posture characterized by critical exposure levels that require immediate remediation to prevent potential unauthorized access and system compromise. The primary threat is identified as CVE-2026-44935: Cross-Namespace Secret Disclosure in Fleet, which warrants immediate attention due to its potential to facilitate unauthorized exfiltration of sensitive organizational credentials within containerized environments. It is the directive of the security office that we transition to a mandatory emergency patching and mitigation posture for all identified critical and high-priority assets within the next 24 to 48 hours.

3. Critical Action List

- Execute immediate emergency patching of all Rancher Fleet instances to mitigate CVE-2026-44935 within 24 hours.
- Implement temporary firewall isolation for all Ghost frontend servers to block x-ghost-preview headers associated with CVE-2026-53943 by the end of this business day.
- Disable or restrict input sanitization on all Rancher workload configuration interfaces to neutralize the command injection vector of CVE-2026-44939 within 24 hours.
- Initiate a comprehensive audit and replacement of QUIC-based service endpoints currently utilizing compromised TLS verification logic for CVE-2026-49457 within 48 hours.
- Review and remediate over-privileged GitHub team memberships within the Rancher authentication provider to address the authorization bypass in CVE-2026-41053 within 72 hours.

4. Quick Reference: All Identified Vulnerabilities

CVE ID	Finding Name	CVSS	Severity	Urgency	CWE
--------	--------------	------	----------	---------	-----

CVE-2026-44935	Cross-Namespace Secret Disclosure...	9.9	Critical	89/100	CWE-863
CVE-2026-53943	Cache-Poisoning XSS in Ghost Fron...	9.6	Critical	86/100	CWE-524
CVE-2026-44939	Rancher YAML Command Injection	9.1	Critical	86/100	CWE-95
CVE-2026-49457	Broken TLS Verification in QUIC	9.1	Critical	82/100	CWE-295
CVE-2026-41053	Rancher GitHub Auth Membership Ex...	8.8	High	79/100	CWE-303
CVE-2026-44938	PSS Bypass in Fleet Agent	8.8	High	79/100	CWE-522
CVE-2026-41052	Rancher Project Owner Host Escala...	9.1	Critical	76/100	CWE-305
CVE-2026-50143	Apify MCP Server Token Exfiltrati...	7.5	High	73/100	CWE-918
CVE-2026-50138	goshs WebDAV Access Control Bypass	9.1	Critical	73/100	CWE-284
CVE-2026-53712	SCRAM Authentication Downgrade in...	8.1	High	68/100	CWE-636
CVE-2026-50151	Credential Forwarding in oras-go ...	7.5	High	68/100	CWE-918
CVE-2026-44937	Fleet Unauthenticated Webhook Reg...	9.1	Critical	68/100	CWE-345
CVE-2026-9795	Privilege Escalation via Scope Ma...	8.1	High	66/100	CWE-266
CVE-2026-50163	oras-go Hardlink Path Traversal	7.8	High	64/100	CWE-22
CVE-2026-50162	oras-go Arbitrary File Write via ...	7.6	High	59/100	CWE-73
CVE-2026-48978	Bearer Token Realm Hijacking in o...	6.5	Medium	56/100	CWE-319
CVE-2026-50139	goshs Token Redemption Race Condi...	4.8	Medium	53/100	CWE-362
CVE-2026-48824	Mailpit JSON Memory Exhaustion DoS	5.3	Medium	48/100	CWE-770
CVE-2026-44936	SSRF in Fleet Bundle Reader	4.2	Medium	45/100	CWE-918
CVE-2026-48819	Prototype Pollution in openapi-ts	7.3	High	43/100	CWE-1321

5. Detailed Vulnerability Findings

CVE-2026-44935

Finding: Cross-Namespace Secret Disclosure in Fleet

CVSS v3.1 Score: 9.9 | Severity: Critical | Urgency Score: 89/100 | CWE: CWE-863

MITRE ATT&CK: T1068, T1552

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	Low
Scope	Changed
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

Rancher Fleet is vulnerable to cross-namespace secret disclosure through unvalidated `valuesFrom` references in the Helm Deployer. The application fails to check the namespace scope of secret references, allowing attackers to reference secrets outside of the target namespace. This leads to the unauthorized exfiltration of sensitive credentials stored across the cluster.

Proof of Concept (PoC):

An attacker with permission to create deployments in a low-privilege namespace creates a ``fleet.yaml`` referencing a secret in a high-privilege system namespace. The Fleet Helm Deployer processes the ``valuesFrom`` reference without verifying that the secret is within the allowed namespace. The secret content is then injected into the attacker's deployment, where they can read and exfiltrate it.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-44935>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-44935>

CVE-2026-53943

Finding: Cache-Poisoning XSS in Ghost Frontend

CVSS v3.1 Score: 9.6 | Severity: Critical | Urgency Score: 86/100 | CWE: CWE-524

MITRE ATT&CK: T1189, T1059

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Changed
Integrity Impact	High

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	High
Availability Impact	High

Description:

The Ghost frontend server is susceptible to a cache-poisoning XSS attack triggered via the `x-ghost-preview` header. The application fails to properly isolate or validate this header value when generating cache keys, allowing injection of malicious scripts into the cached page content. This facilitates the execution of arbitrary JavaScript in the context of other users visiting the site.

Proof of Concept (PoC):

An unauthenticated remote attacker sends a request to the Ghost frontend with a malicious payload injected into the `x-ghost-preview` header. The server caches the response containing the payload, which is then served to subsequent users. When a victim accesses the affected page, the injected JavaScript executes within their session context. This allows the attacker to steal administrative session cookies or perform unauthorized actions on behalf of the victim.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-53943>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-53943>

CVE-2026-44939

Finding: Rancher YAML Command Injection

CVSS v3.1 Score: 9.1 | Severity: Critical | Urgency Score: 86/100 | CWE: CWE-95

MITRE ATT&CK: T1059, T1203

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	High
Scope	Changed
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

Rancher is susceptible to command injection due to unsanitized YAML parameters processed during workload configuration. The application fails to escape user-provided inputs before passing them to the underlying shell command execution framework. An attacker can exploit this to execute arbitrary commands on the Rancher management host.

Proof of Concept (PoC):

An attacker with administrative access modifies a workload YAML template to include shell metacharacters in a configuration field. When Rancher parses and processes the workload, the injected commands are executed by the management server shell. The attacker gains full remote code execution capabilities on the host system, enabling persistent backdoors and cluster-wide control.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-44939>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-44939>

CVE-2026-49457

Finding: Broken TLS Verification in QUIC

CVSS v3.1 Score: 9.1 | Severity: Critical | Urgency Score: 82/100 | CWE: CWE-295

MITRE ATT&CK: T1557, T1560

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Attack Vector	Network	Attack Complexity	Low
Privileges Required	None	User Interaction	None
Scope	Unchanged	Confidentiality Impact	High
Integrity Impact	High	Availability Impact	None

Description:

The QUIC protocol implementation exhibits broken TLS verification logic during the handshake process. The library fails to correctly validate server certificates or enforce path-of-trust requirements, allowing for man-in-the-middle attacks. This compromises the confidentiality and integrity of all QUIC-encrypted traffic.

Proof of Concept (PoC):

An unauthenticated remote attacker positions themselves to intercept QUIC traffic between a client and a server. The attacker provides a self-signed or invalid certificate during the TLS handshake, which the client-side QUIC implementation fails to reject. The attacker successfully performs a man-in-the-middle attack, decrypting and modifying the encrypted traffic stream without the user's knowledge.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-49457>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-49457>

CVE-2026-41053

Finding: Rancher GitHub Auth Membership Expansion

CVSS v3.1 Score: 8.8 | Severity: High | Urgency Score: 79/100 | CWE: CWE-303

MITRE ATT&CK: T1078

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network	Attack Complexity	Low
---------------	---------	-------------------	-----

Privileges Required	Low
Scope	Unchanged
Integrity Impact	High

User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

Rancher's GitHub App authentication provider incorrectly performs team membership expansion, leading to over-inclusive access. The system fails to correctly validate the scope of nested team memberships during the authentication sync. This allows users to inherit excessive permissions that they should not possess based on their direct organization affiliation.

Proof of Concept (PoC):

A low-privileged user adds themselves to a sub-team within a GitHub organization linked to Rancher. Upon the next login sync, the Rancher authentication module incorrectly interprets the nested membership and grants the user organization-wide administrator permissions. The attacker then leverages these elevated rights to manage clusters and configurations outside their assigned role.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-41053>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-41053>

CVE-2026-44938

Finding: PSS Bypass in Fleet Agent

CVSS v3.1 Score: 8.8 | Severity: High | Urgency Score: 79/100 | CWE: CWE-522

MITRE ATT&CK: T1068, T1562

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

The Fleet agent is vulnerable to Pod Security Standard (PSS) bypass via the `addLabelsFromOptions` function. The function fails to validate labels before applying them to a pod, allowing an attacker to inject labels that circumvent security policies enforced by the cluster. This allows for the execution of privileged pods that violate established security constraints.

Proof of Concept (PoC):

An authenticated user with low privileges deploys a Fleet bundle containing specially crafted options for `addLabelsFromOptions`. The Fleet agent processes these options and applies them to the pod labels without verifying their adherence to security policies. This forces the Kubernetes controller to ignore PSS restrictions, allowing the attacker to run a root-privileged pod on the node.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-44938>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-44938>

CVE-2026-41052

Finding: Rancher Project Owner Host Escalation

CVSS v3.1 Score: 9.1 | Severity: Critical | Urgency Score: 76/100 | CWE: CWE-305

MITRE ATT&CK: T1068, T1611

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	High
Scope	Changed
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

The Rancher management interface contains a security flaw allowing privilege escalation from Project Owner to Host-level control. The vulnerability stems from insufficient authorization checks within the workload deployment controller when mapping project-specific secrets. An attacker can exploit this to gain administrative control over the underlying Kubernetes host nodes.

Proof of Concept (PoC):

An attacker with Project Owner privileges submits a Kubernetes deployment manifest containing a specifically crafted volume mount. The Rancher workload controller fails to sanitize the requested path, allowing the container to mount the host's root filesystem. The attacker gains the ability to execute code as the root user on the underlying host node, compromising the entire cluster.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-41052>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-41052>

CVE-2026-50143

Finding: Apify MCP Server Token Exfiltration

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 73/100 | CWE: CWE-918

MITRE ATT&CK: T1530, T1040

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

The Apify Model Context Protocol (MCP) server exhibits a path authority injection vulnerability within its request handler. The implementation fails to properly sanitize path parameters before authority resolution, allowing attackers to manipulate internal routing logic. This permits an attacker to leak sensitive Apify authentication tokens through unauthorized cross-domain request redirection.

Proof of Concept (PoC):

An unauthenticated remote attacker identifies the MCP server endpoint. The attacker sends a request with a crafted path authority string to the actor controller interface. The server process blindly resolves the authority, leading the client to forward authentication tokens to the attacker-controlled host. This enables full unauthorized access to the victim's Apify resources.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-50143>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-50143>

CVE-2026-50138

Finding: goshs WebDAV Access Control Bypass

CVSS v3.1 Score: 9.1 | Severity: Critical | Urgency Score: 73/100 | CWE: CWE-284

MITRE ATT&CK: T1068, T1565

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	High

Description:

The goshs WebDAV listener improperly enforces access control configuration, ignoring the specified --read-only, --upload-only, and --no-delete mode flags. This failure occurs due to an incorrect initialization of the server's permission state during the listener startup phase. Consequently, unauthorized users can modify or delete files on the server despite the intended restricted security configuration.

Proof of Concept (PoC):

An unauthenticated remote attacker targets a goshs server started with the --read-only flag. The attacker sends a DELETE request to an arbitrary resource via the WebDAV interface. The server process ignores the global read-only restriction and deletes the target file. This results in the complete loss of data integrity and availability for the affected system files.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-50138>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-50138>

CVE-2026-53712

Finding: SCRAM Authentication Downgrade in OnGres

CVSS v3.1 Score: 8.1 | Severity: High | Urgency Score: 68/100 | CWE: CWE-636

MITRE ATT&CK: T1557, T1560

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	High
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

The OnGres SCRAM authentication implementation is vulnerable to a silent channel-binding downgrade attack. By misconfiguring certificate algorithm negotiation, the server fails to enforce secure binding requirements, allowing an attacker to intercept or degrade the authentication handshake. This exposes authentication traffic to potential relay or man-in-the-middle attacks.

Proof of Concept (PoC):

An unauthenticated remote attacker performs a man-in-the-middle attack on the OnGres authentication channel. The attacker sends a crafted handshake request forcing the server to select an unsupported or insecure certificate algorithm. The server accepts this insecure configuration, effectively disabling channel binding. The attacker can then capture sensitive authentication data for subsequent replay or credential impersonation.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-53712>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-53712>

CVE-2026-50151

Finding: Credential Forwarding in oras-go Blob Upload

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-918

MITRE ATT&CK: T1528, T1530

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

The oras-go blob upload component is susceptible to credential forwarding due to unvalidated Location headers. When the server receives a redirect, it automatically forwards credentials to the provided URL without confirming it belongs to a trusted realm. This allows a malicious registry to exfiltrate user credentials during the upload lifecycle.

Proof of Concept (PoC):

An unauthenticated remote attacker hosts a malicious registry server. The attacker initiates a blob upload request and responds with a 302 redirect containing a Location header pointing to an attacker-controlled endpoint. The oras-go client follows this redirect, forwarding the user's Bearer token to the malicious registry. The attacker collects the tokens, enabling further unauthorized access to private registries.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-50151>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-50151>

CVE-2026-44937

Finding: Fleet Unauthenticated Webhook Regex Injection

CVSS v3.1 Score: 9.1 | Severity: Critical | Urgency Score: 68/100 | CWE: CWE-345

MITRE ATT&CK: T1190, T1565

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

Rancher Fleet is vulnerable to a regex injection attack in the unauthenticated webhook processor. The application uses unsanitized repository URL components within regex-based validation logic. This allows attackers to manipulate matching behavior, potentially leading to unauthorized repository registration or webhook bypass.

Proof of Concept (PoC):

An unauthenticated remote attacker sends a specially crafted POST request to the Fleet webhook endpoint with a payload containing regex metacharacters in the repository URL field. The validator incorrectly interprets these characters, allowing the attacker to bypass the domain whitelist check. The attacker successfully registers a malicious repository, triggering unauthorized code deployment across the Fleet managed environment.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-44937>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-44937>

CVE-2026-9795

Finding: Privilege Escalation via Scope Mapping in Keycloak

CVSS v3.1 Score: 8.1 | Severity: High | Urgency Score: 66/100 | CWE: CWE-266

MITRE ATT&CK: T1068, T1484

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N

Attack Vector	Network	Attack Complexity	Low
Privileges Required	Low	User Interaction	None
Scope	Unchanged	Confidentiality Impact	High
Integrity Impact	High	Availability Impact	None

Description:

Keycloak suffers from an improper scope mapping enforcement mechanism during token issuance. The authentication engine fails to adequately validate requested scopes against the authenticated user's permissions, leading to an over-provisioning of rights. This allows users to escalate their privileges by obtaining access tokens with unauthorized elevated scopes.

Proof of Concept (PoC):

An authenticated user with low privileges requests a token from the Keycloak authentication endpoint with an elevated scope parameter. The server processes the request without validating that the user is permitted to hold this scope, issuing an access token with administrator privileges. The attacker uses this token to perform unauthorized administrative actions across the managed environment.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-9795>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-9795>

CVE-2026-50163

Finding: oras-go Hardlink Path Traversal

CVSS v3.1 Score: 7.8 | Severity: High | Urgency Score: 64/100 | CWE: CWE-22

MITRE ATT&CK: T1005, T1083

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:L/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H

Attack Vector	Local	Attack Complexity	Low
---------------	-------	-------------------	-----

Privileges Required	None
Scope	Unchanged
Integrity Impact	High

User Interaction	Required
Confidentiality Impact	High
Availability Impact	High

Description:

The oras-go library contains a path traversal vulnerability in its tar extraction logic, specifically when handling hardlink entries with relative linknames. The function resolves the hardlink destination relative to the current working directory, failing to validate that the resolved path resides within the intended extract target. This allows attackers to write files to arbitrary locations on the host filesystem during extraction.

Proof of Concept (PoC):

An attacker crafts a malicious tar archive containing a hardlink with a relative path (e.g., ../../etc/shadow). When a user extracts this archive using the vulnerable oras-go function, the code resolves the path incorrectly and bypasses the extraction root directory. The attacker successfully writes or overwrites sensitive files on the local filesystem, potentially escalating privileges or gaining persistence.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-50163>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-50163>

CVE-2026-50162

Finding: oras-go Arbitrary File Write via Symlink

CVSS v3.1 Score: 7.6 | Severity: High | Urgency Score: 59/100 | CWE: CWE-73

MITRE ATT&CK: T1083, T1565

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:H/A:L

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	Low
Availability Impact	Low

Description:

The oras-go file store mechanism fails to correctly validate paths when performing write operations, allowing symlink traversal. By embedding a symlink in a storage payload, an attacker can trick the file store into writing data outside the intended working directory. This poses a significant threat to system integrity, as arbitrary files can be overwritten.

Proof of Concept (PoC):

An authenticated user with low privileges submits an OCI image containing a maliciously crafted symlink entry. The oras-go file store processing function follows the symlink without verifying its destination against the allowed workingDir. This results in the server writing the content of the image into a restricted directory on the host filesystem, such as configuration files.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-50162>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-50162>

CVE-2026-48978

Finding: Bearer Token Realm Hijacking in oras-go

CVSS v3.1 Score: 6.5 | Severity: Medium | Urgency Score: 56/100 | CWE: CWE-319

MITRE ATT&CK: T1552, T1550

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:L/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	High
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

The oras-go library is vulnerable to credential exfiltration through insecure handling of Bearer token realms. A malicious registry can manipulate the realm response, tricking the client into sending refresh tokens to an attacker-controlled endpoint. This results in the compromise of user credentials stored within the registry interaction layer.

Proof of Concept (PoC):

An unauthenticated remote attacker sets up a registry that returns a malicious WWW-Authenticate header. The oras-go client parses this header and initiates an authentication exchange with the attacker's server, providing the sensitive refresh token. The attacker captures the refresh token, gaining indefinite access to the user's private repository assets.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-48978>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-48978>

CVE-2026-50139

Finding: goshs Token Redemption Race Condition

CVSS v3.1 Score: 4.8 | Severity: Medium | Urgency Score: 53/100 | CWE: CWE-362

MITRE ATT&CK: T1068, T1190

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:L/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	High
User Interaction	None
Confidentiality Impact	Low
Availability Impact	None

Description:

The goshs file sharing component contains a race condition in the share-link token redemption logic. The server fails to enforce atomic constraints on the download limit counter during concurrent token verification requests. This permits attackers to bypass the established download count threshold, leading to unauthorized access to restricted files.

Proof of Concept (PoC):

An unauthenticated remote attacker identifies a valid file share-link. The attacker sends a burst of simultaneous HTTP requests targeting the token redemption parameter. The server fails to lock the counter variable during the validation check, allowing multiple downloads for a single-use token. This results in the complete exfiltration of the intended file beyond its usage limits.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-50139>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-50139>

CVE-2026-48824

Finding: Mailpit JSON Memory Exhaustion DoS**CVSS v3.1 Score: 5.3 | Severity: Medium | Urgency Score: 48/100 | CWE: CWE-770****MITRE ATT&CK: T1499****CVSS v3.1 Scoring Criteria:***Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L*

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	Low

Description:

Mailpit is vulnerable to a memory exhaustion Denial of Service (DoS) attack via unbounded JSON body processing in its API endpoints. The application fails to enforce size limits on requests sent to `/api/v1/messages`, `/api/v1/tags`, and `/api/v1/message/{id}/release`. This allows an attacker to consume all available server memory by sending large, specially crafted JSON payloads.

Proof of Concept (PoC):

An unauthenticated remote attacker sends a large POST request containing an extremely deeply nested JSON structure to the `/api/v1/messages` endpoint. The server attempts to deserialize the payload into memory without checking its size or complexity. This causes a rapid increase in memory usage, eventually leading to a process crash or service unavailability for all other users.

*Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-48824>**Ref: <https://www.cve.org/CVERecord?id=CVE-2026-48824>***CVE-2026-44936****Finding: SSRF in Fleet Bundle Reader****CVSS v3.1 Score: 4.2 | Severity: Medium | Urgency Score: 45/100 | CWE: CWE-918****MITRE ATT&CK: T1082, T1190****CVSS v3.1 Scoring Criteria:***Vector: CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:U/C:L/I:L/A:N*

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	High
User Interaction	None
Confidentiality Impact	Low
Availability Impact	None

Description:

Rancher Fleet contains a Server-Side Request Forgery (SSRF) vulnerability in the bundle reader component due to unvalidated Helm repository URLs in ``fleet.yaml``. An attacker can specify arbitrary URLs, forcing the Fleet controller to make outbound network requests to internal or external services. This can be used to probe internal network infrastructure or bypass firewall controls.

Proof of Concept (PoC):

An attacker crafts a ``fleet.yaml`` file with a repository URL pointing to an internal metadata service (e.g., 169.254.169.254). The Fleet bundle reader executes the request to this URL, returning the response body in the Fleet status logs. The attacker reads the sensitive instance metadata, potentially gaining access to cloud credentials or

internal configuration information.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-44936>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-44936>

CVE-2026-48819

Finding: Prototype Pollution in openapi-ts

CVSS v3.1 Score: 7.3 | Severity: High | Urgency Score: 43/100 | CWE: CWE-1321

MITRE ATT&CK: T1210

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L

Attack Vector	Network	Attack Complexity	Low
Privileges Required	None	User Interaction	None
Scope	Unchanged	Confidentiality Impact	Low
Integrity Impact	Low	Availability Impact	Low

Description:

The `@hey-api/openapi-ts`` library exhibits a prototype chain substitution vulnerability within its `buildClientParams`` template generation. An attacker can supply a malicious key, such as ``$<slot>__proto__``, which the library fails to sanitize before injection. This allows the modification of global JavaScript object prototypes, potentially leading to remote code execution or application instability.

Proof of Concept (PoC):

An attacker identifies an API input field processed by openapi-ts that is converted into client parameters. The attacker sends a request containing the key ``__proto__`` followed by a payload that overrides existing object methods (e.g., `toString`). The application processes this, modifying the global environment in the victim's application. This manipulation can lead to arbitrary logic execution whenever common object operations are performed.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-48819>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-48819>

6. Methodology & Data Sources

This report was generated by the Auto-CTI Autonomous Cyber Threat Intelligence Pipeline, an automated multi-agent system designed to simulate a real-world Security Operations Center (SOC) workflow. The pipeline operates in three sequential stages: (1) the Scout Agent collects the latest CVE disclosures from the GitHub Advisory Database and cross-references active threat pulses via AlienVault OTX; (2) the Triage Agent performs structured analysis using the CVSS v3.1 scoring standard, assigns CWE root-cause classifications, maps each vulnerability to relevant MITRE ATT&CK techniques, and computes a composite Urgency Score; (3) the Publisher Agent synthesizes the triaged data into this executive briefing. All CVE identifiers, CVSS scores, and CWE mappings are sourced directly from official databases and are verifiable via the references provided in Section 5. Severity classification follows the CVSS v3.1 standard: Critical (9.0-10.0), High (7.0-8.9), Medium (4.0-6.9), Low (0.1-3.9).

Primary Data Sources:

- GitHub Advisory Database -- <https://github.com/advisories>
- NIST National Vulnerability Database (NVD) -- <https://nvd.nist.gov/>

- AlienVault Open Threat Exchange (OTX) -- <https://otx.alienvault.com/>
- MITRE ATT&CK Framework -- <https://attack.mitre.org/>
- CVSS v3.1 Specification -- <https://www.first.org/cvss/v3.1/specification-document>
- Common Weakness Enumeration (CWE) -- <https://cwe.mitre.org/>
- CVE Program -- <https://www.cve.org/>